FEATURE 14 OF 14 | PRIORITY P1

URL Reputation Checks

Priority	P1
Judging criteria served	Completeness (35) | Innovation (20)
Estimated effort	Medium (~3-5 hrs) (rough estimate)
Depends on	Rule-Based Detection (basic link heuristics)

Purpose

Links are the most common scam delivery method. The MVP flags risky link shapes locally; this feature adds a second layer that asks a trusted threat-intelligence source whether the link is a known bad address.

What it must do

- Extract every URL from the message (including those without http://).
- Layer 1 (P0 inside Rule Detection): local heuristics - no network needed.
- Layer 2 (P1): query a reputable threat-intelligence service and show the result as supporting evidence.
- Three honest result states: **Known bad**, **No known reports (not a guarantee of safety)**, **Could not check**.
- Never open or fetch the suspicious URL from the user's browser or from your server just to inspect it.

How it should work

- **Local heuristics (Layer 1):** URL shortener domains (bit.ly, tinyurl, etc.); IP address instead of a name; punycode / xn-- domains; '@' inside the URL; very long or many-subdomain hosts; unusual endings (.xyz, .top, .click); no HTTPS combined with login/KYC wording; brand name inside an unrelated domain (e.g. sbi-kyc-update.xyz).
- **Lookalike check:** compare the domain with an allowlist of official bank/UPI domains using edit distance (Levenshtein, distance 1-2) and common character swaps (rn for m, 0 for o, l for i).
- **External lookup (Layer 2):** use a reputable source such as Google Safe Browsing, URLhaus or PhishTank. Check each service's current terms, rate limits and whether free use is allowed for your project before relying on it.
- Call the service from your server (keeps API keys secret), with a short timeout, and cache results for a few hours.
- **Security note:** if you ever expand shortened links server-side, block private/internal IP ranges to avoid server-side request forgery (SSRF), and use a short timeout and redirect limit.
- A 'No known reports' answer only means the address is not in that list - brand-new scam sites are often not listed yet. Say so on screen.

UI / UX notes

- Links are displayed as inert text (not clickable) in the result, with a risk chip next to each.
- Show the real domain in bold and the rest dimmed so users learn to read addresses.
- Offer 'Find the official website' hint: type the company name into your search engine or use the official app, don't use the link.

Edge cases and risks

- Message with multiple links: each gets its own chip; points still counted once for the SUSPICIOUS_LINK rule.

- Legitimate shortened link (e.g. from a real company): flagged as 'shortened - cannot see destination', not as 'bad'.
- Reputation service down: result state 'Could not check'; local heuristics still apply.

Acceptance tests

Try this	Expected result
http://sbi-kyc-update.xyz/login	Flagged: bank name in unofficial domain + odd ending
https://sbi.co.in	Not flagged (allowlist)
http://192.168.4.7/login	Flagged: IP address host
Reputation API timeout	'Could not check'; heuristics result still shown
Link that API reports as unknown	Wording: 'No known reports' - never 'safe'

Demo tip for the judges

> Show the example link broken into its parts: brand word + wrong ending = classic lookalike.